



OPA/Gatekeeper (K8s)

Equipo:
Miguel Ángel Carreto
Velázquez
Jonathan Garzón
Morales



Open Policy Agent

¿Qué es (OPA)?

Open Policy Agent:

- Es un motor de políticas de propósito general de código abierto
- Permite definir políticas como código (“Policy as Code”), separando la lógica de políticas de la lógica de la aplicación.

¿Cómo surge?

¿Para qué se usa?

Para imponer reglas de autorización, cumplimiento, auditoría en entornos cloud-nativos, Kubernetes, CI/CD, etc

OPA fue iniciado por Styra y aceptado por la Cloud Native Computing Foundation (CNCF) el 29 de marzo de 2018.

¿Qué es OPA Gatekeeper?



Es una extension
de Open Policy
Agent para
Kubernetes

Extension de OPA

Utiliza un
webhook*
mediante una API
que posee
Kubernetes

Webhook de API

Permite definir y
aplicar politicas de
seguridad y
gobernanza

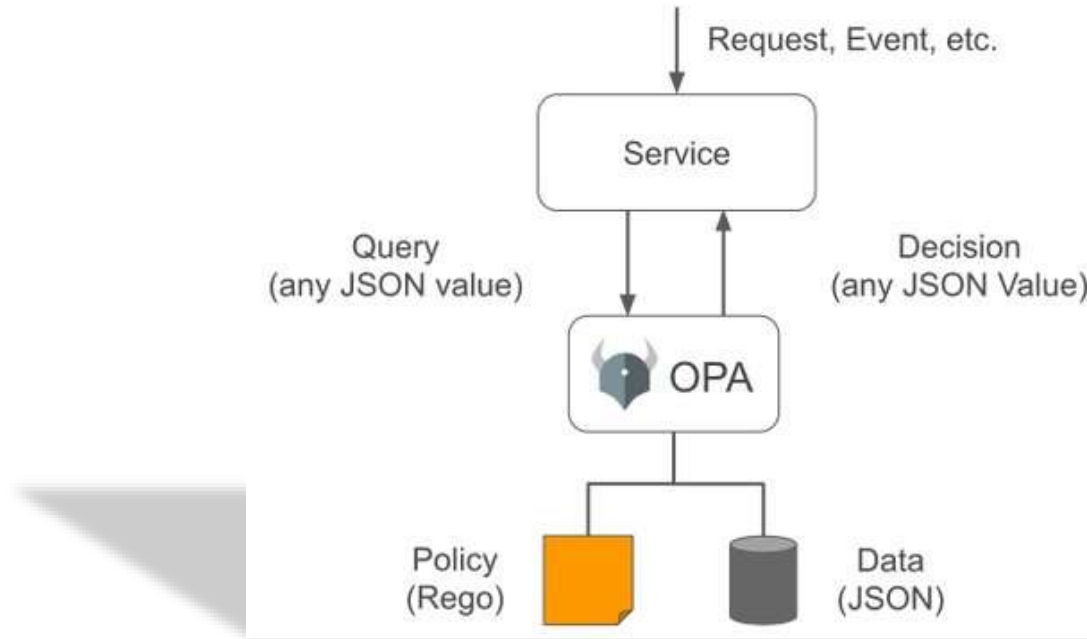
**Políticas de
Seguridad**

Las reglas se
escriben en el
lenguaje Rego

Lenguaje Rego

*Un **webhook** es un **mecanismo** para que un **sistema** notifique a otro automáticamente cuando ocurre un evento.

Arquitectura básica de OPA

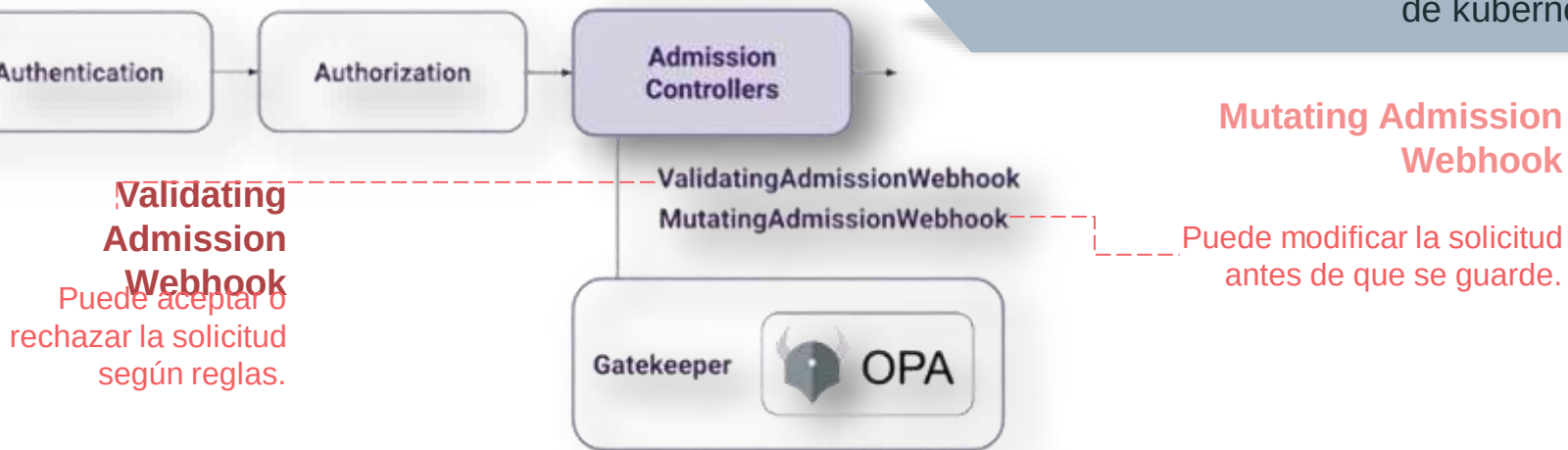


OPA recibe una consulta, toma una decisión, basada en la política y los datos, luego envía una decisión, que puede ser un dato estructurado arbitrario

Admission Controllers

En Kubernetes, un **Admission Controller** es un **componente del control plane** que **intercepta las solicitudes** (requests) dirigidas al API Server después de la **autenticación y la autorización**, pero antes de que los objetos se almacenen en etcd.

Son una serie de reglas específicas que están en el binario del servidor de la API de kubernetes, los cuales podemos habilitar o desactivar cuando arrancamos el servidor de kubernetes.



Arquitectura de OPA / Gatekeeper

Esta diseñado completamente para **Kubernetes** (se integra nativamente con el API Server de Kubernetes)

Crea nuevos objetos para la API de Kubernetes mediante.

CRDs y un Controller

(En Kubernetes, los **CRDs (Custom Resource Definitions)** te permiten definir tus propios tipos de recursos, como si fueran nativos)

Kubernetes se basa en el patrón de **controladores (controllers)** que ejecutan un ciclo llamado **“Reconciliation Loop”** o **bucle de reconciliación**.

El controller observa continuamente el “estado actual” del clúster (por ejemplo, los Pods que existen).

1

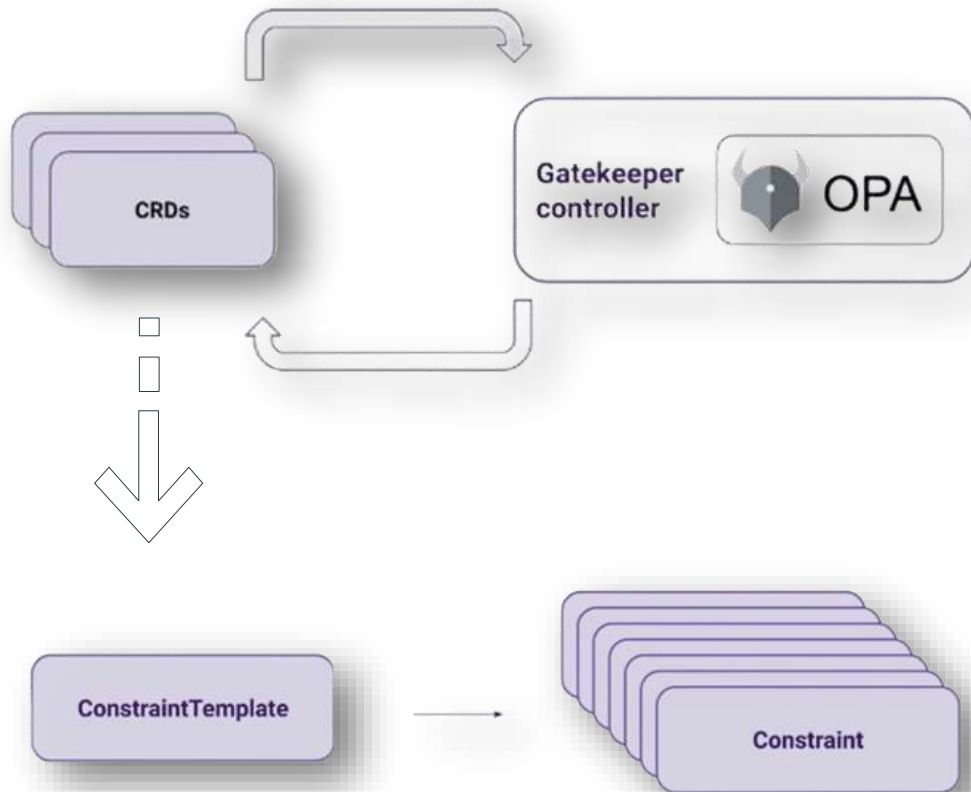
2

Compara ese estado con el “estado deseado” (lo que las políticas dicen que debería ser).

Si ve una diferencia, actúa para reconciliarla (corrige, bloquea, o reporta).

3

Arquitectura de OPA / Gatekeeper



ConstraintTemplate (la plantilla de la regla)

Es un recurso que define la lógica de validación usando el lenguaje Rego (el lenguaje de políticas de OPA). Ahí se describe qué debe revisarse cuando un usuario crea o modifica un recurso en Kubernetes.

Constraint (la política aplicada)

Una vez que tienes la plantilla, puedes crear varias instancias (Constraints) que usan esa lógica, pero apuntando a distintos recursos o namespaces.

Modo "Audit" vs. Modo "Enforce"

Gatekeeper tiene dos modos de funcionamiento principales:

Enforce

Bloquea solicitudes que violan políticas en tiempo real, durante la creación o modificación de objetos

Audit

Revisa los recursos que ya existen en el clúster y genera reportes si no cumplen las políticas de forma periódica (no bloquea nada)

Implementación.

